GUÍA DE ESTUDIO

IDS/IPS – Detección y Prevención de Intrusos

UNIDAD	SESIÓN	TIPO	NIVEL
2	4	ESTUDIO	AVANZADO

CUGDL - Universidad de Guadalajara
Arquitectura de Sistemas de Seguridad
Licenciatura en Ciberseguridad

Autor: Carlos Pulido Rosas
Marzo 2026

OBJETIVOS DE APRENDIZAJE

1. Distinguir entre IDS e IPS - su función, posición en la arquitectura de red y cuándo usar cada uno.
2. Comparar los métodos de detección basados en firmas versus anomalías, y argumentar las ventajas y limitaciones de cada enfoque.
3. Identificar los tipos de IDS/IPS (NIDS, HIDS, NIPS, HIPS) y determinar cuál aplica a cada escenario de arquitectura.
4. Conectar el IDS/IPS con la Capa 3 de Defensa en Profundidad y entender cómo se integra con el NGFW y el SIEM.

CONTEXTO

En la sesión anterior diseñamos las zonas de la red - DMZ, VLANs y NGFW. Ahora agregamos la capa de detección: el IDS/IPS. Si el NGFW es la puerta con llave, el IDS es la cámara de seguridad y el IPS es el guardia que puede cerrar la puerta automáticamente.

Un atacante que logra cruzar el perímetro no debería poder operar sin ser detectado. El IDS/IPS es el sistema que transforma la visibilidad en respuesta.

1. IDS vs. IPS - ¿Detectar o Prevenir?

La distinción fundamental entre IDS e IPS no es técnica — es de comportamiento ante una amenaza detectada. Ambos sistemas analizan el tráfico de red o la actividad de un host buscando patrones maliciosos. La diferencia está en lo que hacen cuando encuentran algo sospechoso.

Un IDS (Intrusion Detection System) observa y alerta. Genera un log, envía una notificación al equipo de seguridad y deja que el tráfico continúe. Es como una cámara de vigilancia: registra todo, pero no interviene. Un IPS (Intrusion Prevention System) observa, alerta y actúa. Puede bloquear el paquete, terminar la conexión o aislar el host comprometido en tiempo real.

Criterio	IDS	IPS
Modo de operación	Pasivo - solo monitorea	Inline - intercepta el tráfico
Respuesta a amenaza	Alerta y registra	Bloquea y registra
Posición en la red	Fuera del flujo de tráfico (tap/span)	Dentro del flujo de tráfico
Riesgo de falso positivo	Bajo - solo alerta	Alto - puede bloquear tráfico legítimo
Impacto en rendimiento	Mínimo	Moderado - agrega latencia
Caso de uso ideal	Auditoría, cumplimiento, visibilidad	Protección activa en tiempo real

ANALOGÍA - Data Engineering: pipeline con validación

El IDS es como un logger pasivo en un pipeline: registra cada transformación y alerta si detecta datos corruptos, pero deja que el pipeline continúe.

El IPS es como un schema validator estricto con circuit breaker: si un registro no cumple el esquema, rechaza el mensaje completo antes de que llegue al siguiente stage.

La diferencia clave: el IDS nunca detiene el pipeline. El IPS puede pararlo - y eso tiene un costo si se activa por error.

2. Tipos de IDS/IPS — NIDS, HIDS, NIPS, HIPS

La clasificación principal de IDS/IPS se basa en dónde se despliega el sistema: en la red (Network-based) o en un host individual (Host-based). Cada enfoque tiene visibilidad sobre amenazas distintas y se complementan en una arquitectura de defensa en profundidad.

2.1 NIDS / NIPS - Basados en Red

Un NIDS (Network Intrusion Detection System) analiza el tráfico que fluye por un segmento de red. Se conecta a un puerto SPAN del switch o a un tap de red para recibir una copia de todo el tráfico sin interferir en él. Tiene visibilidad sobre todos los dispositivos en ese segmento - una sola sonda puede proteger decenas de hosts simultáneamente.

Características del NIDS/NIPS

- Visibilidad amplia - monitorea todos los dispositivos en el segmento de red.
- No depende del sistema operativo del host - protege cualquier dispositivo, incluyendo IoT.
- No puede ver tráfico cifrado end-to-end a menos que tenga acceso a las claves (SSL inspection).
- Punto único de monitoreo - si el NIDS falla, toda la visibilidad de ese segmento se pierde.
- Herramientas comunes: Snort, Suricata, Zeek (antes Bro).

2.2 HIDS / HIPS — Basados en Host

Un HIDS (Host Intrusion Detection System) se instala directamente en el sistema operativo del host que protege. En lugar de analizar tráfico de red, monitorea actividad interna: llamadas al sistema, cambios en archivos críticos, modificaciones al registro, procesos en ejecución y logs del sistema operativo.

Características del HIDS/HIPS

- Visibilidad profunda - ve lo que el NIDS no puede: actividad interna del sistema operativo.
- Detecta amenazas que nunca generan tráfico de red - malware que opera localmente, escalación de privilegios.
- Puede ver tráfico cifrado - porque lo analiza después de que el host lo descifra.
- Requiere instalación en cada host - escalabilidad más compleja que el NIDS.
- Herramientas comunes: OSSEC, Wazuh, Tripwire, Windows Defender for Endpoint.

Criterio	NIDS/NIPS	HIDS/HIPS
Cobertura	Todos los hosts en el segmento	Un solo host
Visibilidad de tráfico cifrado	Limitada (sin SSL inspection)	Total (analiza post-descifrado)

Actividad interna del OS	No	Sí - procesos, archivos, logs
Escalabilidad	Alta - una sonda por segmento	Baja - agente por host
Amenazas que detecta mejor	Ataques de red, escaneos, DDoS	Malware, rootkits, escalación de privilegios
Dónde se despliega	Switch SPAN / tap de red	Agente instalado en el host

3. Métodos de Detección — Firmas vs. Anomalías

Independientemente de si el sistema es NIDS o HIDS, todos los IDS/IPS usan uno o más métodos para decidir si un comportamiento es malicioso. Los dos enfoques principales - detección por firmas y detección por anomalías - representan un trade-off fundamental entre precisión y capacidad de detectar amenazas nuevas.

3.1 Detección por Firmas (Signature-based)

La detección por firmas compara el tráfico o la actividad del sistema contra una base de datos de patrones conocidos de ataques. Cada firma es una regla que describe cómo se ve un ataque específico - por ejemplo, la firma de un exploit de EternalBlue incluye los bytes exactos que aparecen en el payload del ataque.

Ventajas y limitaciones de la detección por firmas

- ✅ Alta precisión - las alertas tienen contexto claro ("detectado exploit CVE-2017-0144").
- ✅ Bajo índice de falsos positivos - si el patrón coincide, hay alta probabilidad de ataque real.
- ✅ Rápido de implementar - las firmas se actualizan automáticamente desde feeds del proveedor.
- ❌ Ciega ante amenazas nuevas - si el ataque no tiene firma conocida, no lo detecta.
- ❌ Evasión por variación - un atacante puede modificar ligeramente el ataque para evitar la firma.
- ❌ Requiere actualizaciones constantes - una base de firmas desactualizada es un IDS inútil.

3.2 Detección por Anomalías (Anomaly-based)

La detección por anomalías establece un baseline del comportamiento normal de la red o del host, y alerta cuando detecta desviaciones significativas de ese baseline. No necesita conocer el ataque específico - solo necesita reconocer que algo es inusual. Un servidor que normalmente recibe 100 conexiones por hora y de repente recibe 10,000 está mostrando una anomalía.

Ventajas y limitaciones de la detección por anomalías

- ✅ Detecta amenazas desconocidas - incluyendo zero-days y ataques internos.
- ✅ No depende de firmas actualizadas - el baseline se construye automáticamente.
- ✅ Efectivo contra amenazas lentas y persistentes (APT) que intentan pasar desapercibidas.
- ❌ Alto índice de falsos positivos - cualquier cambio legítimo en el comportamiento puede generar alertas.
- ❌ Período de entrenamiento - necesita tiempo para aprender qué es normal antes de ser efectivo.
- ❌ Si el atacante opera dentro del baseline, no lo detecta - un ataque lento y silencioso puede pasar.

ANALOGÍA — Detección de anomalías en Data Engineering

Firma = regla de validación explícita: si el campo 'status' tiene valor 'DROP_TABLE', rechazar. Conoces exactamente qué buscar.

Anomalía = detección de outliers en un pipeline de ML: el modelo aprendió que los pedidos normales son de $10-$500. Un pedido de $50,000 dispara una alerta, aunque no hay una regla que diga que $50,000 es inválido.

Los sistemas modernos combinan ambos - igual que un pipeline de calidad de datos usa tanto reglas explícitas como modelos estadísticos.

4. Posición en la Arquitectura de Red

La efectividad de un IDS/IPS depende en gran medida de dónde se coloca en la arquitectura. Una sonda mal posicionada puede tener visibilidad nula sobre el tráfico más crítico, aunque el sistema sea técnicamente excelente.

Posición	Qué ve	Para qué sirve
Fuera del firewall (Internet)	Todo el tráfico entrante sin filtrar	Ver ataques antes de que el firewall los filtre - útil para inteligencia de amenazas
Entre firewall e Internet (DMZ)	Tráfico que el firewall permitió hacia la DMZ	Detectar ataques contra servicios públicos - servidor web, DNS, correo
Entre DMZ y red interna	Tráfico que cruza hacia la red interna	Detectar movimiento lateral desde DMZ - posición más crítica
Dentro de la red interna	Tráfico entre VLANs internas	Detectar amenazas internas y movimiento lateral entre segmentos
En cada host (HIDS)	Actividad local del sistema operativo	Detectar amenazas que no generan tráfico de red visible

En la práctica, la arquitectura ideal combina al menos dos posiciones: un NIDS entre la DMZ y la red interna para detectar movimiento lateral, y agentes HIDS en los servidores críticos para visibilidad interna. El NGFW de la sesión anterior ya incorpora capacidades básicas de IPS - los IDS/IPS dedicados agregan profundidad de análisis y capacidad de detección de anomalías que el NGFW por sí solo no tiene.

5. IDS/IPS y SIEM - Del Evento al Incidente

Un IDS que genera alertas sin que nadie las procese no protege a nadie. El SIEM (Security Information and Event Management) es el sistema que centraliza, correlaciona y prioriza las alertas de todos los sensores de seguridad - incluyendo el IDS/IPS, el NGFW, los logs del sistema operativo y las aplicaciones.

Cómo trabajan juntos IDS/IPS y SIEM

- El IDS/IPS genera eventos individuales: 'conexión sospechosa desde 192.168.10.5 al puerto 445'.
- El SIEM correlaciona: 'el mismo host generó 50 conexiones fallidas en 10 segundos a diferentes IPs internas' - esto ya es un patrón de escaneo lateral.
- El SIEM prioriza: combina la alerta del IDS con datos de vulnerabilidad del host destino y genera un incidente de alta severidad.
- El equipo SOC recibe un incidente con contexto completo, no 50 alertas aisladas.
- Herramientas SIEM comunes: Splunk, IBM QRadar, Microsoft Sentinel, Wazuh (open source).

ANALOGÍA - IDS/IPS como sensores de un observability stack

El IDS/IPS es el equivalente a los exporters de Prometheus: genera métricas y eventos de seguridad.

El SIEM es Grafana + AlertManager: centraliza los datos, define umbrales y escala alertas al equipo correcto.

Sin el SIEM, el IDS es como tener logs de Prometheus sin ningún dashboard — los datos existen pero nadie los lee.

CASO REAL: Capital One - Brecha por falta de detección de anomalías (2019)

En 2019, una ex-empleada de AWS explotó una misconfiguration en el WAF de Capital One para acceder a los metadatos de instancias EC2. Desde ahí obtuvo credenciales IAM temporales con las que descargó datos de más de 100 millones de clientes en 30 minutos.

Conexión con esta guía: el acceso fue técnicamente válido — las credenciales IAM eran legítimas. Un firewall tradicional no habría detectado nada. Un sistema de detección de anomalías habría notado que una sola identidad descargó cientos de buckets de S3 en minutos — un patrón completamente fuera del baseline normal. AWS GuardDuty (un servicio equivalente a un NIDS en cloud) generó alertas, pero no estaban configuradas para escalar automáticamente. El incidente tardó días en detectarse.

Lección de arquitectura: el IDS/IPS sin integración con SIEM y sin runbooks de respuesta definidos es como tener una alarma de incendios sin nadie que escuche.

PREGUNTAS DE REFLEXIÓN

1. Un banco decide implementar un IPS en modo inline entre su DMZ y su red interna. El primer día de operación, el IPS bloquea tráfico legítimo de un proveedor de pagos y causa una interrupción de 2 horas. ¿Qué estrategia de despliegue habrías recomendado para evitar este escenario? ¿Cuándo es apropiado pasar de IDS a IPS?
2. La detección por anomalías requiere un período de entrenamiento para aprender el baseline normal. ¿Qué riesgos existen si un atacante ya está dentro de la red durante ese período de entrenamiento? ¿Cómo cambiaría tu diseño de arquitectura considerando este escenario?
3. En el caso de Capital One, las alertas existían pero no escalaron a tiempo. ¿Es este un problema de tecnología o de proceso organizacional? ¿Qué cambios de arquitectura — técnicos y organizacionales — habrías implementado para que el incidente se detectara en minutos en lugar de días?

RECURSOS

- [Docs] Snort - IDS/IPS open source de referencia - https://www.snort.org (gratuito)
- [Docs] Suricata - alternativa a Snort con soporte nativo multi-thread - https://suricata.io (gratuito)
- [Docs] Wazuh - HIDS + SIEM open source, muy usado en LATAM - https://wazuh.com (gratuito)
- [Docs] NIST SP 800-94 - Guide to Intrusion Detection and Prevention Systems - https://csrc.nist.gov/publications/detail/sp/800-94/final (gratuito)
- [Video] NetworkChuck - 'IDS vs IPS' - https://youtube.com/@NetworkChuck (~10 min)
- [TryHackMe] Room: 'Snort' - https://tryhackme.com/room/snort - práctica con reglas de detección reales